

Analisi del ransomware WannaCrypt0r.exe

Pratica S9/L3 — Analisi statica e dinamica di un campione ransomware | Materiale didattico per studenti di cybersecurity

Obiettivo e metodo

Questo documento analizza il campione WannaCrypt0r.exe combinando due approcci complementari. L'**analisi statica** esamina il file senza eseguirlo (con CFF Explorer e PEStudio, sulla VM FlareVM) per capire com'è costruito: hash, librerie, funzioni importate e sezioni. L'**analisi dinamica** esegue il campione in un ambiente isolato (la sandbox online **tria.ge**) per osservare cosa fa realmente a runtime: file creati, cifratura, persistenza, rete. Il campione è una minaccia reale: per questo non è stato avviato su FlareVM, ma detonato solo nella sandbox di Triage, isolata dal resto della rete.

1. Identificazione del campione

Il primo passo di ogni analisi è l'**impronta identificativa**: hash e metadati permettono di riconoscere il file e cercarlo nelle basi dati di threat intelligence.

Nome / tipo	WannaCrypt0r.exe — PE 32-bit, subsystem GUI, compilato con Visual C++ 6.0
Dimensione	3,35 MB (3.514.368 byte)
SHA-256	ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa
MD5	84C82835A5D21BBCF75A61706D8AB549
SHA-1	5FF465AFAABCBF0150D1A3AB2C2E74F3A4426467
Rilevazione	VirusTotal 65/70 · tria.ge score 10/10 · famiglia: WannaCry
Mascheratura	Metadati di diskpart.exe (l'utility di partizionamento di Windows): il file finge di essere un componente legittimo di sistema.

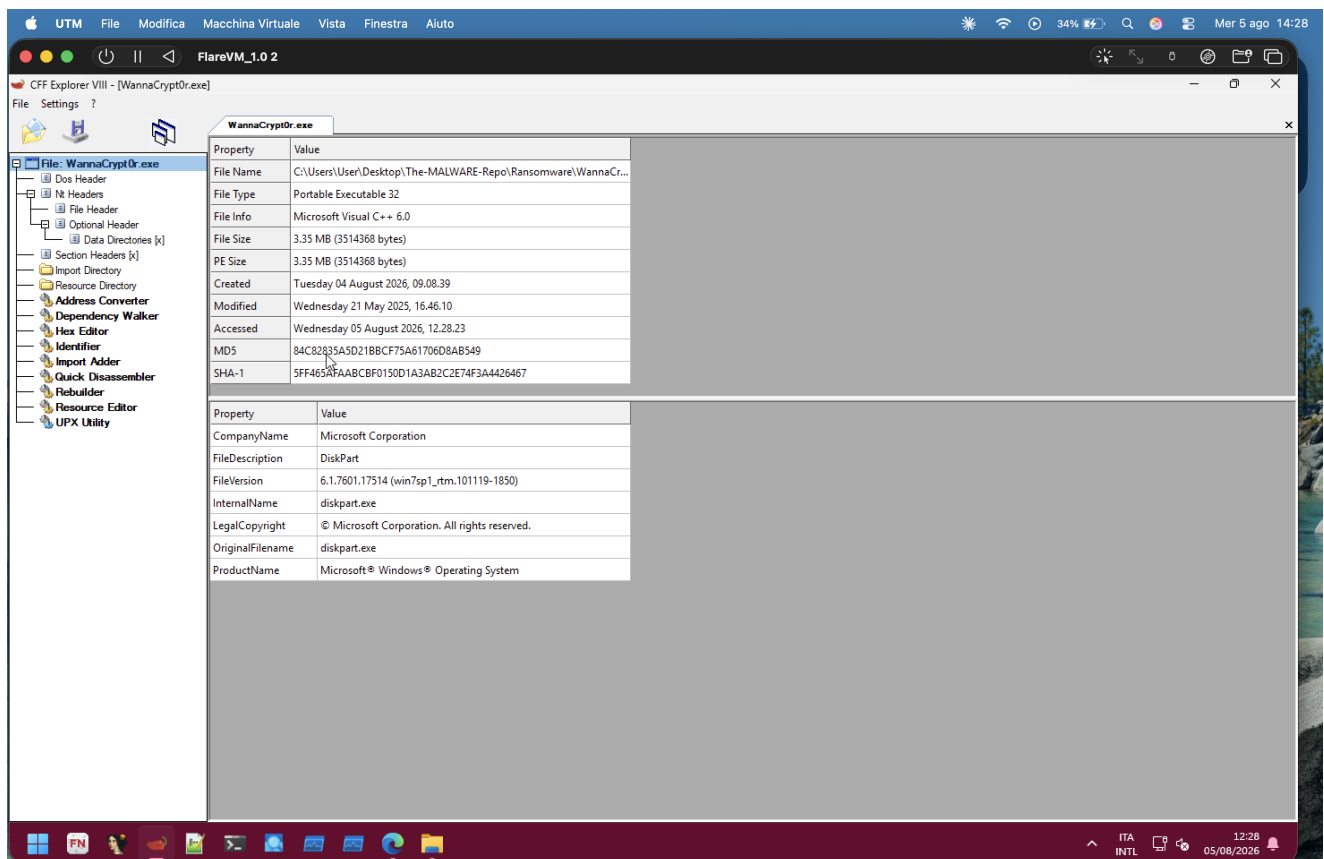


Fig. 1 — CFF Explorer: informazioni generali e metadati. Si noti la mascheratura da «diskpart.exe» di Microsoft.

Concetto chiave — dropper vs worm

WannaCry è composto da più parti. Il **worm** (mssecsvc.exe, ~3,6 MB) contiene il kill-switch e l'exploit EternalBlue per propagarsi via rete. Il **dropper/encryptor** (tasksche.exe, 3.514.368 byte) si occupa della cifratura. Per hash e dimensione, il nostro campione è il **dropper**: questo spiega perché nell'analisi dinamica vedremo la cifratura ma non la scansione SMB.

2. Analisi statica — librerie e funzioni

Le **librerie importate** (DLL) e le **funzioni** che il programma richiama rivelano le sue capacità potenziali. Il campione importa 114 funzioni da 4 librerie:

Libreria	Funz.	Descrizione
KERNEL32.dll	54	API di base del SO: file, memoria, processi, servizi. Cuore delle operazioni del malware.
MSVCRT.dll	49	Microsoft C Runtime: funzioni standard del C (stringhe, memoria, I/O).
ADVAPI32.dll	10	API avanzate: registro di Windows, servizi e CryptoAPI (crittografia).
USER32.dll	1	Interfaccia utente: uso minimo, coerente con un processo che lavora in background.

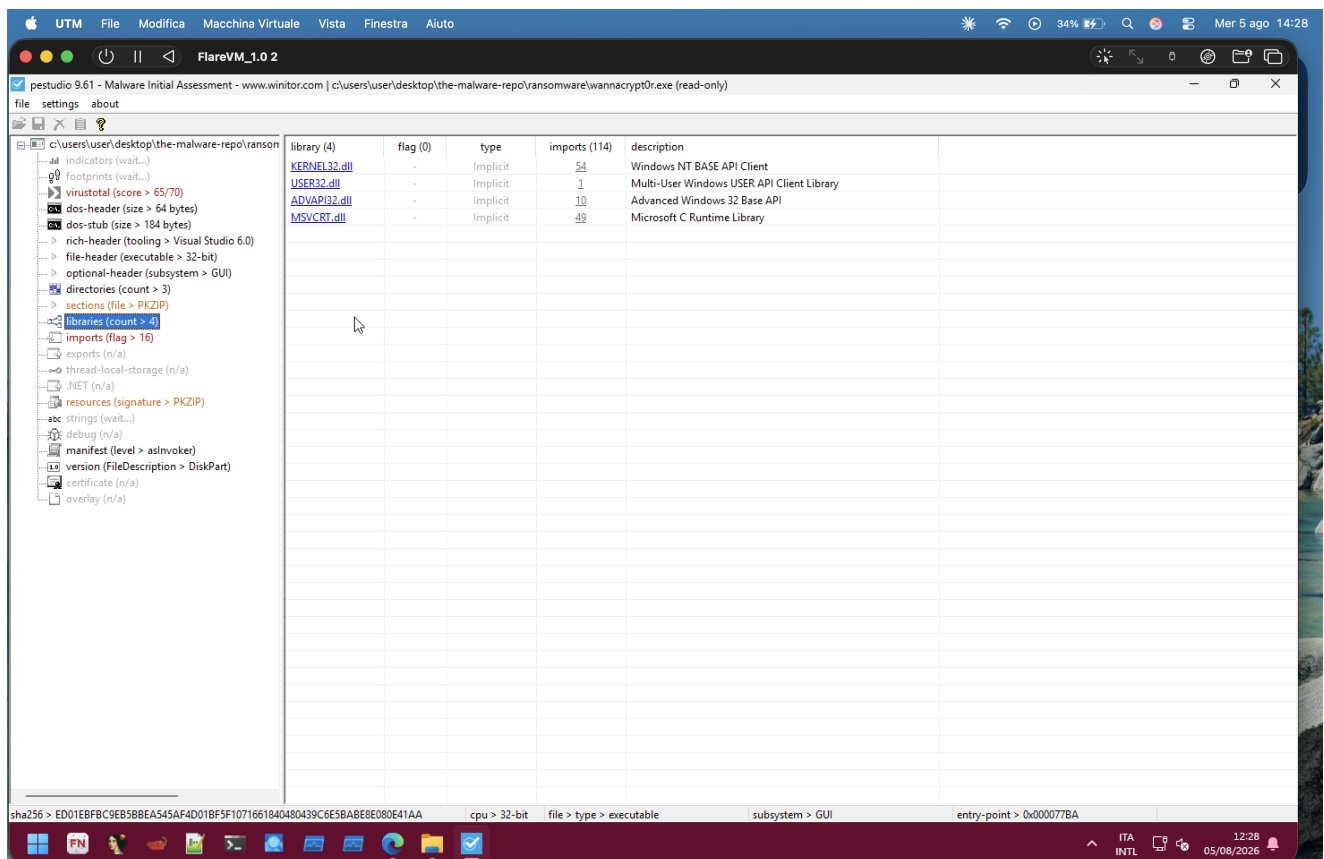


Fig. 2 — PESTudio: le 4 librerie importate con le rispettive descrizioni.

Funzioni sospette (16 flaggate da PESTudio). Raggruppate per finalità, raccontano già il comportamento del ransomware:

- **Servizio e persistenza:** `OpenSCManagerA`, `CreateServiceA`, `StartServiceA`, `RegCreateKeyW`, `RegSetValueExA` — installano un servizio e chiavi di registro per riavviarsi da soli.
- **File system (drop e cifratura):** `CreateFileA`, `WriteFile`, `ReadFile`, `CopyFileA`, `CreateDirectoryW/A`, `SetFileAttributesW` — creano cartelle, scrivono file e ne nascondono gli attributi.
- **Esecuzione e unpacking:** `CreateProcessA`, `VirtualAlloc`, `VirtualProtect` — lanciano processi figli ed eseguono il payload estratto in memoria.
- **Crittografia:** `CryptReleaseContext` (CryptoAPI), `rand/srand` — usate per generare chiavi e nomi casuali.

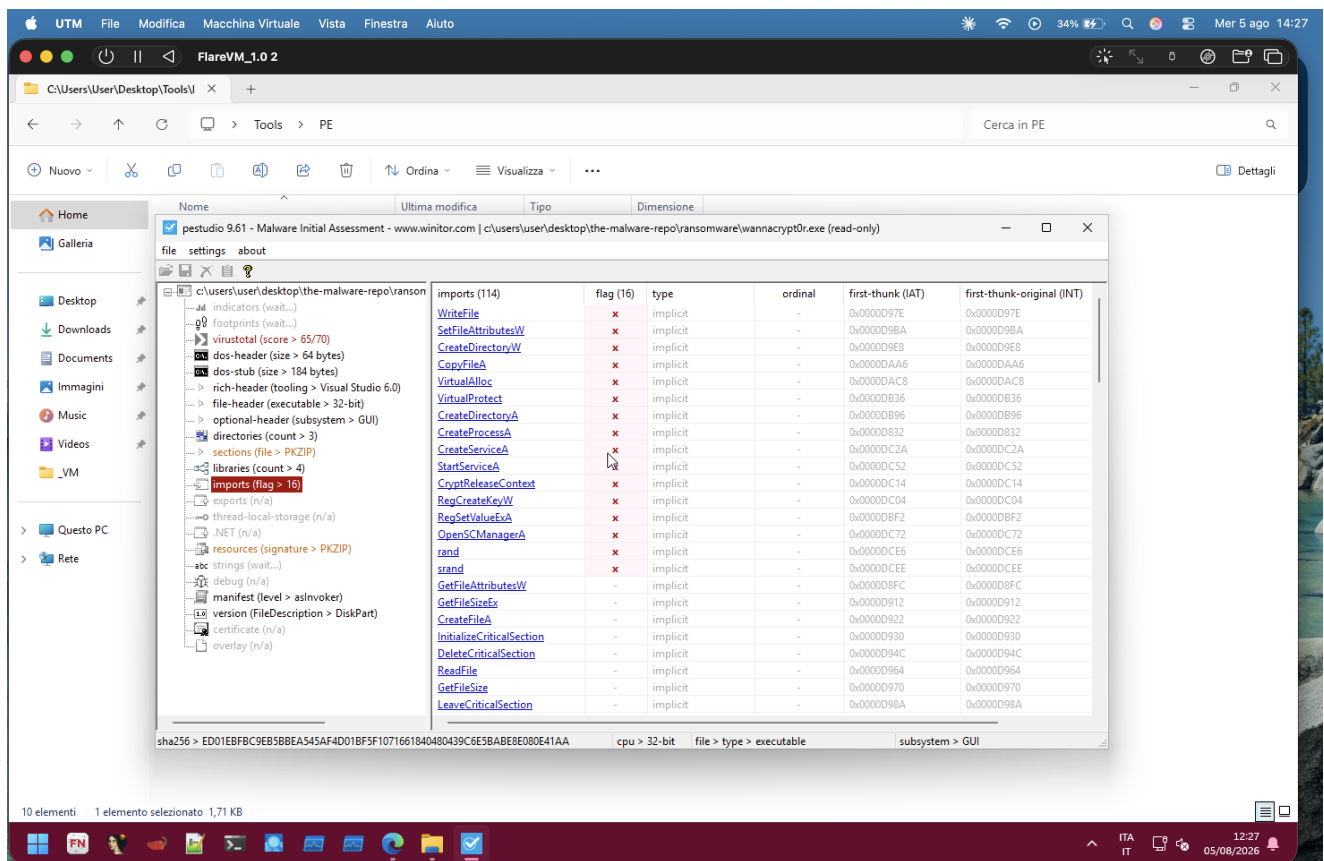


Fig. 3 — PESTudio: funzioni importate evidenziate (flag). In rosso quelle ritenute a rischio.

3. Analisi statica — sezioni

Le **sezioni** sono i blocchi in cui il file PE è suddiviso. L'**entropia** (0–8) misura la casualità dei dati: valori alti indicano compressione o cifratura. Il campione ha 4 sezioni:

Sezione	Entropia	% file	Caratteristiche	Descrizione
.text	6.404	0,82%	0x60000020 (R+X)	Codice eseguibile del dropper.
.rdata	-	0,70%	0x40000040 (R)	Dati di sola lettura (import, costanti).
.data	-	0,23%	0xC0000040 (R+W)	Dati scrivibili (variabili globali).
.rsrc	-	98,14%	0x40000040 (R)	Risorse: contiene l'archivio PKZIP con il payload.

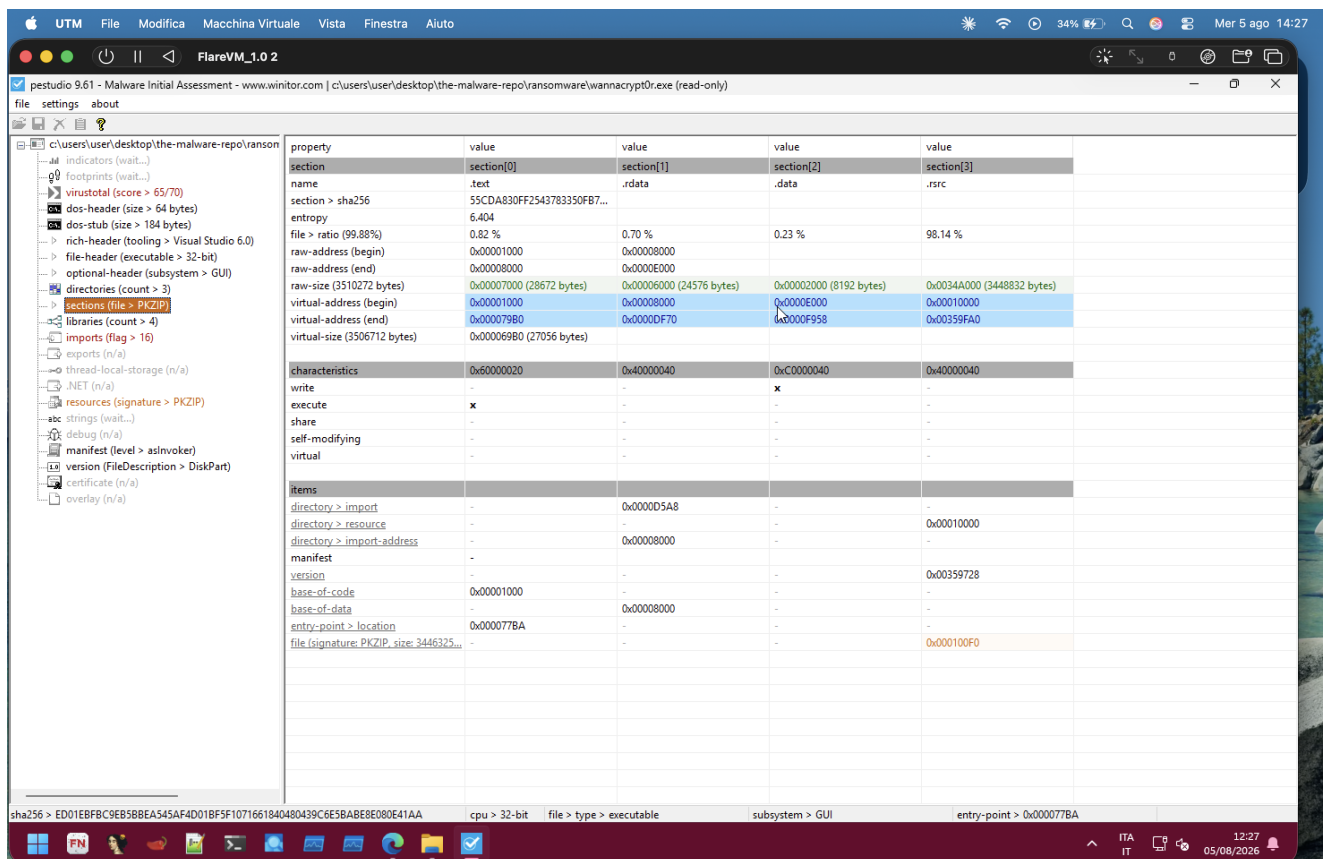


Fig. 4 — PESTudio: tabella delle sezioni. La sezione .rsrc occupa il 98,14% del file.

Il dato chiave — il payload nascosto nelle risorse

A differenza del campione della S9/L2 (che aveva una sezione .text auto-modificante), qui l'anomalia è la sezione **.rsrc** che da sola occupa il **98% del file**. PESTudio la identifica come archivio **PKZIP protetto da password** (~3,44 MB): dentro ci sono i veri componenti di WannaCry. Il dropper, a runtime, li estrae ed esegue. La logica malevola quindi non è nel codice visibile, ma nel payload impacchettato.

4. Analisi dinamica — sandbox tria.ge

Eseguendo il campione nella sandbox, l'analisi passa dal «com'è fatto» al «cosa fa». Triage assegna un punteggio di pericolosità di **10/10** e classifica il campione come famiglia **WannaCry**, con tag ransomware, worm, spyware, stealer, oltre alle categorie MITRE (impact, persistence, defense evasion, discovery, execution, privilege escalation).

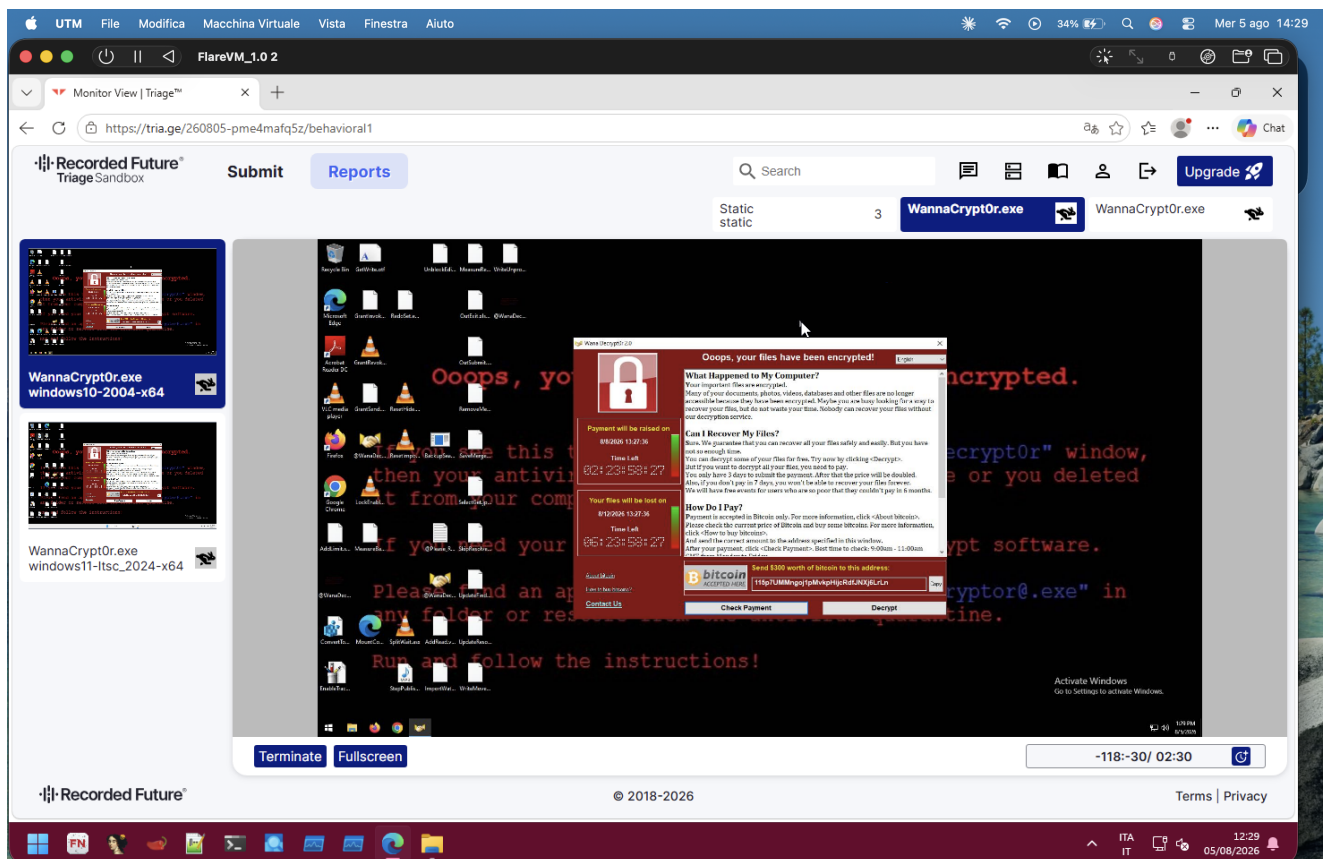


Fig. 5 — Detonazione in sandbox: il desktop viene sostituito dalla schermata di WannaCry e si apre «Wana Decrypt0r 2.0».

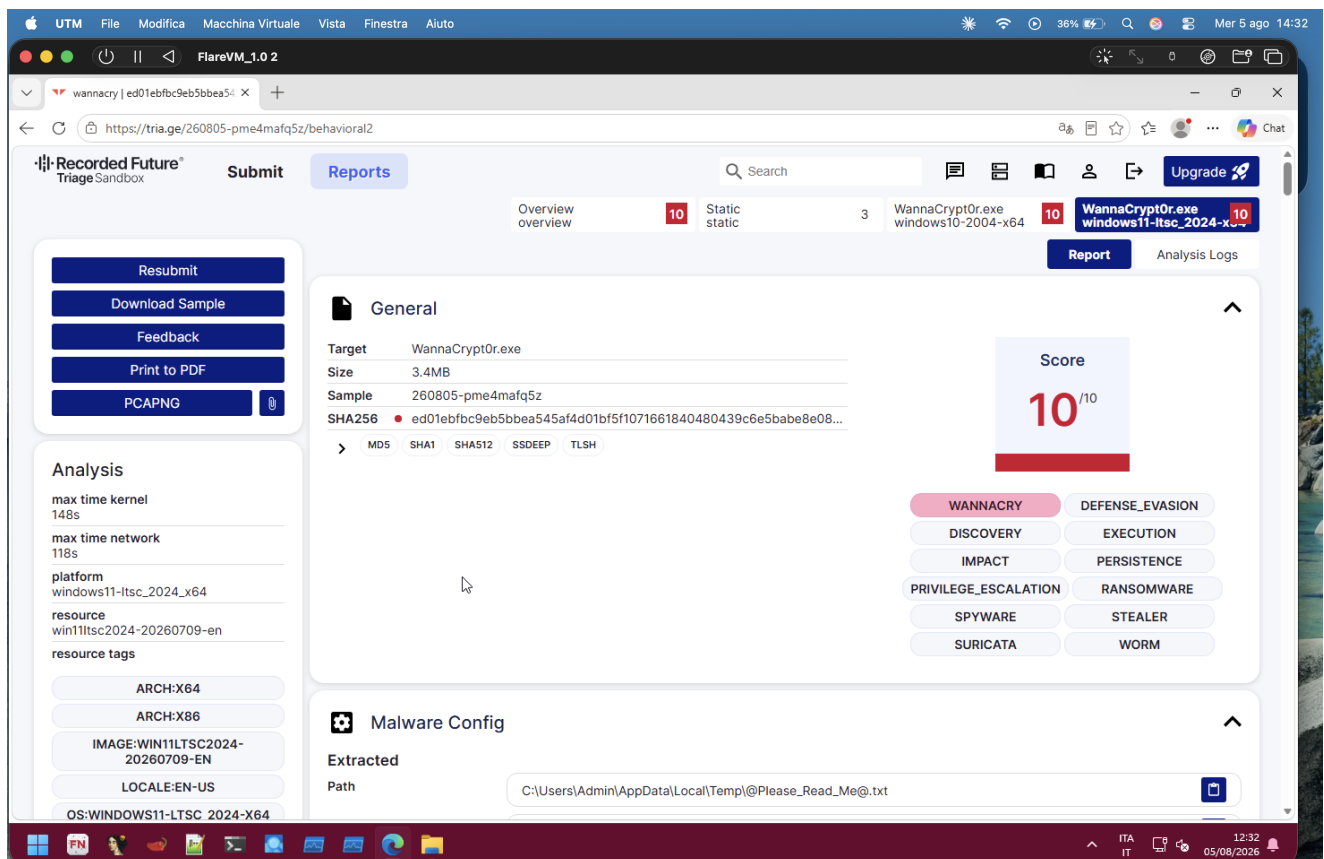


Fig. 6 — Report Triage: score 10/10, famiglia WannaCry e categorie di comportamento rilevate.

Configurazione estratta e nota di riscatto

La sandbox estrae automaticamente la **malware config**: la nota di riscatto viene scritta in C:\Users\Admin\AppData\Local\Temp\@Please_Read_Me@.txt e chiede **300 \$ in Bitcoin**, rimandando al decryptor @WanaDecryptor@.exe. L'indirizzo del wallet estratto è 115p7UMMngo1pMvkpHijcRdfJNXj6LrLn.

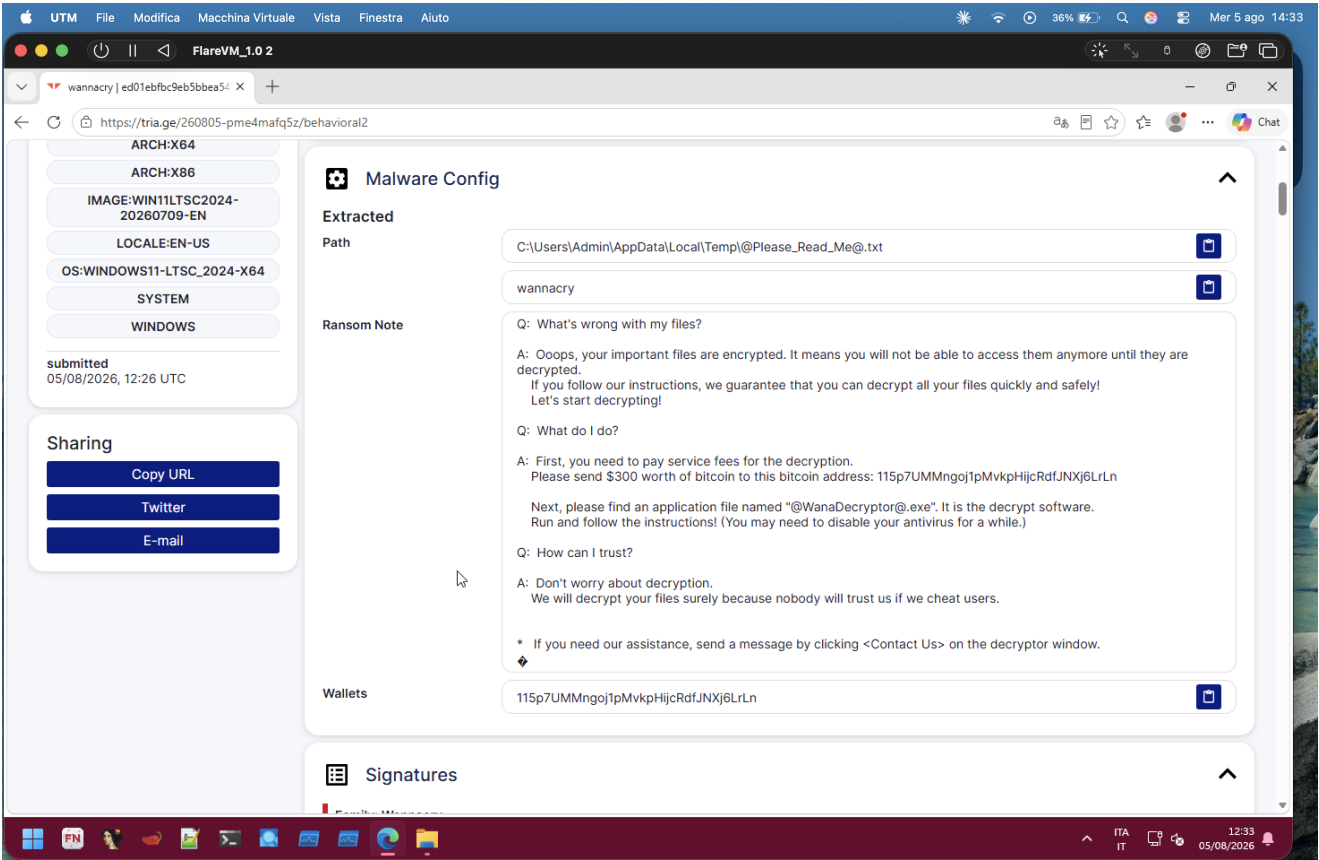


Fig. 7 — Malware config: testo della nota di riscatto e wallet Bitcoin estratti automaticamente.

Comportamenti osservati (signatures / TTP)

Categoria	Comportamento rilevato
Impatto / anti-recovery	Elimina le shadow copies e usa il servizio Volume Shadow Copy per impedire il ripristino dei file; imposta lo sfondo del desktop con la nota di riscatto.
Persistenza	Crea un file nella cartella Startup, aggiunge una chiave Run nel registro e installa un servizio: si riavvia al logon.
Esecuzione / unpacking	Esegue EXE e DLL estratti (dropped), lancia one-liner cmd.exe e uno script VBScript: estrae ed avvia i componenti dal .rsrc.
Evasione / privilegi	Modifica i permessi di file e cartelle (icaccls) e fa uso sospetto di AdjustPrivilegeToken (53 IoC).
Discovery	Rileva la lingua di sistema, enumera dispositivi di archiviazione e processi in esecuzione.
Rete	Alert Suricata per traffico verso nodi Tor: canale usato per C2 e pagamento.

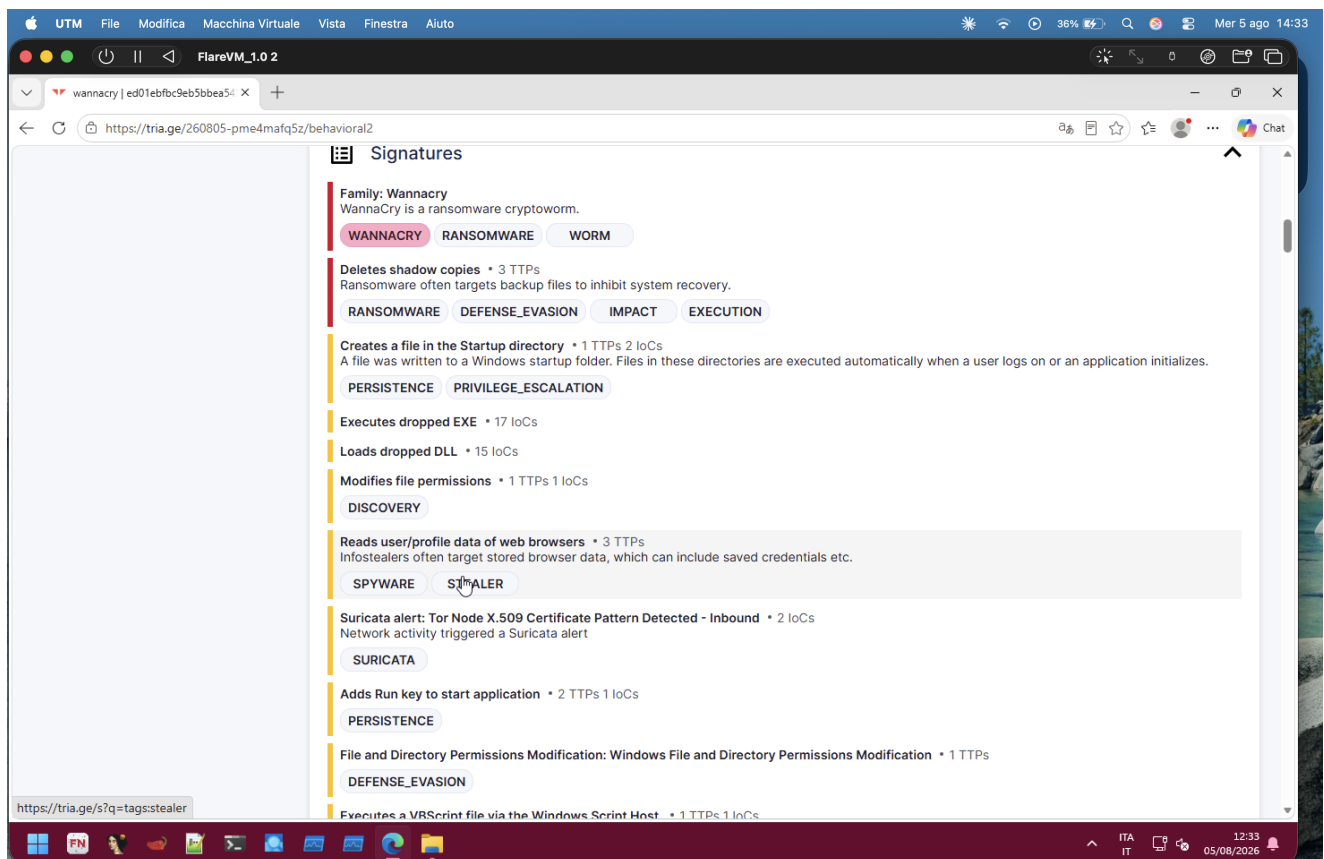


Fig. 8 — Triage signatures (1): famiglia WannaCry, eliminazione shadow copies, persistenza, Tor.

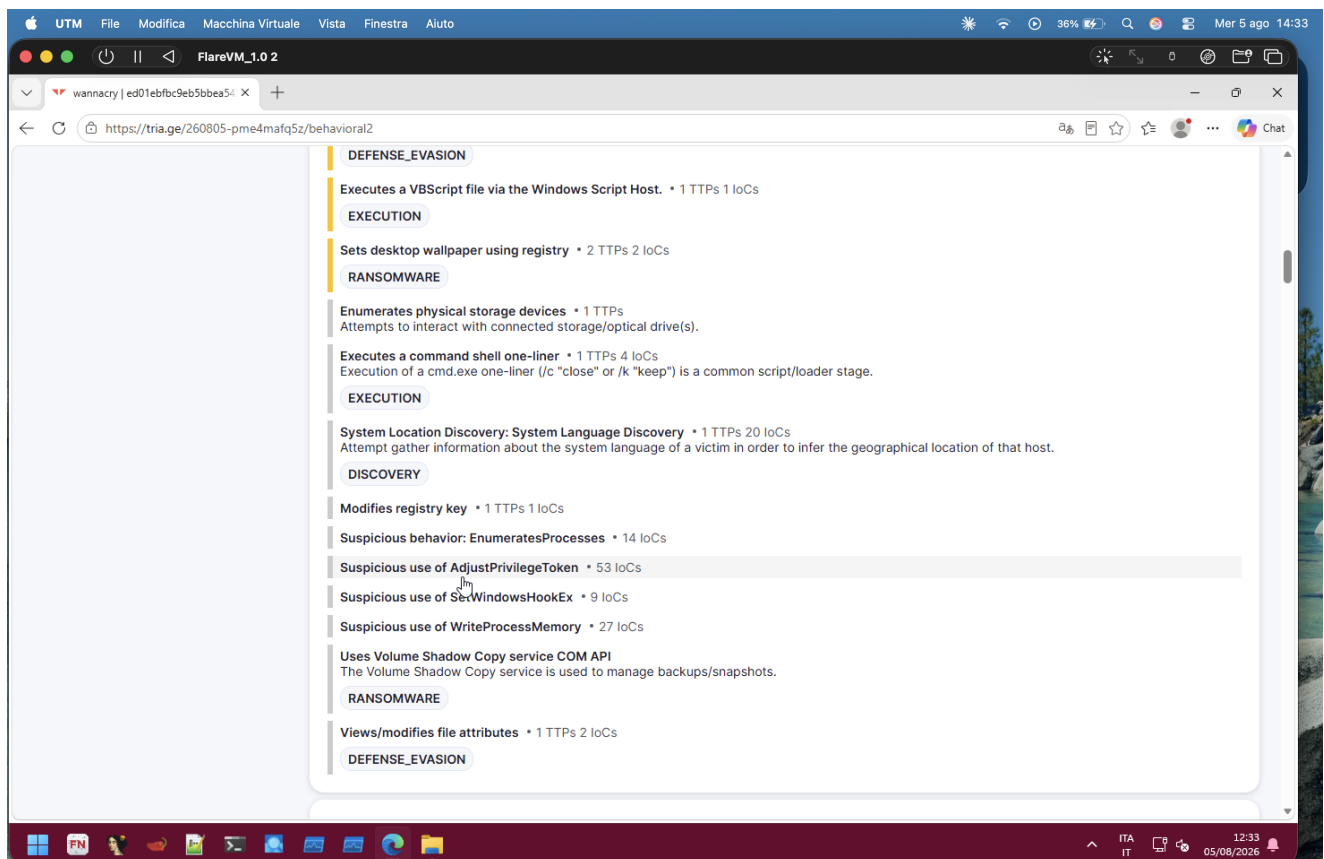


Fig. 9 — Triage signatures (2): wallpaper via registro, uso di AdjustPrivilegeToken, SetWindowsHookEx, WriteProcessMemory.

5. Considerazione finale

Le due analisi convergono su un quadro coerente. Staticamente, WannaCrypt0r .exe è un PE mascherato da diskpart .exe in cui il 98% del file è un archivio protetto da password nascosto nelle risorse, con import orientati a servizi, registro, file system e crittografia. Dinamicamente, la sandbox conferma il comportamento tipico del ransomware **WannaCry**: estrazione ed esecuzione del payload, cifratura dei file con richiesta di riscatto in Bitcoin, persistenza tramite servizio e chiavi Run, eliminazione delle shadow copies per impedire il recupero, e comunicazione via Tor.

Un'osservazione di precisione, importante dal punto di vista metodologico: nel report dinamico **non** compaiono il contatto al dominio kill-switch né la scansione SMB/EternalBlue. Ciò conferma quanto ipotizzato staticamente: questo campione è il **componente dropper/encryptor**, non il worm. La sua funzione è la **cifratura**, mentre la propagazione via rete risiede nel componente mssecsvc .exe. Riconoscere quale componente di una minaccia modulare si sta analizzando è una competenza centrale nell'analisi malware.

Nota metodologica e di sicurezza: l'analisi statica è stata condotta con CFF Explorer e PEStudio 9.61 sul file in sola lettura, all'interno di FlareVM. L'analisi dinamica è stata eseguita sulla sandbox isolata tria.ge (sample 260805-pme4mafq5z). Trattandosi di malware reale, il campione non è mai stato eseguito su FlareVM. Le descrizioni di API e comportamenti riflettono la documentazione standard e i riferimenti pubblici sulla famiglia WannaCry.